

the pazienti trattati con mobocertinib;
Efficacia: valutazione dell'efficacia del mobocertinib
in pazienti pretrattati con carcinoma polmonare non a
piccole cellule metastatico con esone 20 ins dell'EGFR.”

2. La valutazione dell'istanza

L'istanza di consultazione preventiva è stata esaminata in conformità con le disposizioni del Regolamento e del Codice. In particolare, si è proceduto a verificare se le condizioni previste dall'art. 110 del Codice e dall'art. 36 del Regolamento fossero soddisfatte. Si è constatato che l'istanza presenta un adeguato livello di motivazione e che il protocollo di ricerca è stato sottoposto al parere favorevole del comitato etico competente. Inoltre, è stata effettuata una valutazione d'impatto ai sensi dell'art. 35 del Regolamento, che ha evidenziato i rischi per i diritti e le libertà degli interessati e le misure adottate per mitigarli.

3. Le prescrizioni

Alla luce di quanto sopra, si ritiene che l'istanza di consultazione preventiva possa essere accolta, sottoponendo però l'Azienda a specifiche prescrizioni per garantire la protezione dei dati personali. Pertanto, si stabilisce quanto segue:

- L'Azienda deve garantire che i dati personali trattati siano limitati a quelli necessari per raggiungere gli obiettivi dello Studio.
- Deve essere garantita la sicurezza dei dati trattati, adottando misure tecniche e organizzative adeguate.
- L'Azienda deve informare gli interessati, ove possibile, riguardo al trattamento dei loro dati personali e ai diritti ad essi connessi.
- Deve essere effettuata una revisione periodica della valutazione d'impatto per garantire che le misure di protezione siano sempre adeguate.

4. Conclusioni

In conclusione, si autorizza l'Azienda Ospedaliera Universitaria Careggi a procedere con lo Studio “MOBO-Real OSS22465”, nel rispetto delle prescrizioni sopra indicate e delle disposizioni vigenti in materia di protezione dei dati personali.

Firenze, 18 luglio 2023

IL GARANTE PER LA PROTEZIONE DEI DATI PERSONALI

Pasquale Stanzione

cellula (NSCLC). Pertanto, è possibile che alcuni pazienti non siano rintracciabili o che non possano essere informati del trattamento a causa della rarità della loro condizione”.

****1. Real Population:****

Effectiveness: to evaluate in a real, non-selected population, ORR, disease control rate (DCR),

duration of response (DOR), and time to progression (TTP).

****2. Secondary Objectives:****

- Overall survival (OS)
- Progression-free survival (PFS)
- Correlation between outcome and clinical characteristics (age, sex, smoking history, comorbidities, metastatic sites/disease burden, ECOG PS, previous treatments)
- Description of outcome and biological characteristics (type of mutation)
- Assessment of the percentage of patients in treatment at 3, 6, and 12 months from the start
- Identification of a subgroup of patients who benefit from the treatment.

It is also indicated that “[...] data from patients currently being treated with mobocertinib or those who have discontinued treatment for any reason” will be collected, using “an online platform (<https://www.project-redcap.org/>) available at our University (University of Florence), activating all Oncology Units involved in the protocol.” In particular, through this platform, each involved oncology unit will be able to provide data by accessing the platform with a username and password. To this end, each participating center may indicate up to two names among the staff designated to upload data to the aforementioned platform.

“The data will be collected and recorded in compliance with Italian laws and international regulations regarding GCP and privacy, also according to the general principles established by the Helsinki Declaration and its subsequent updates. The database will be protected by credentials held exclusively by the investigators. The names of the patients will be anonymized, assigning each patient a coded alphanumeric identification code. None of the documents related to the study will contain identifying information about the patient. The head of the clinical center will archive the original informed consents in a locked cabinet. The Study Coordinator will archive a copy of the informed consents in a locked cabinet and will keep a list of study participants and their codes in a double-coded identification file.”

In the protocol, it is also stated that “The data and anonymization measures manager is the Principal Investigator. Only the investigators included in the study will have access to the data and results before their publication. The names of the patients will be anonymized, assigning each an alphanumeric coded value. [...] At the end of the study, the Study Coordinator will destroy this file, eliminating all links between study participants, the data, and the samples collected during the research of the patients included in the study.”

In this regard, it was clarified during the investigation that the Principal Investigator (PI) “in the Company, is qualified as a person expressly designated pursuant to 2-quaterdecies of the Code. With the General Director's Provision No. 378 of May 24, 2019, General Regulation on the protection of data 2016/679/EU. Determinations regarding organizational measures for compliance with European regulations: assignment of functions and tasks to specifically designated subjects pursuant to art. 2-quaterdecies of Legislative Decree 196/2003, in the Company we have redefined the expressly designated person as the Data Processing Manager, meaning the natural person who, specifically responsible for a given activity, is specifically tasked with the data processing necessary for that activity, also concerning the authorized persons involved in it.”

It was also clarified that “the ‘anonymization measures’ are improperly referred to, at least where it is observed that the data ‘will be anonymized, assigning each an alphanumeric coded value.’”

It is then stated that “Each living patient will be administered a written informed consent, which must be signed after receiving appropriate explanations. As provided by the Privacy Authority [...] data for scientific research purposes will be processed without informed consent for deceased patients and/or those who cannot be contacted at the time of enrollment, after making every reasonable effort to contact them (verification of living status, consultation of data reported in clinical documentation, use of any provided phone contacts, as well as obtaining contact data from the registry of insured persons or the resident population).”

In this regard, in the section of the impact assessment titled “How are the interested parties informed of

the processing?” it is indicated that “Data for scientific research purposes will be processed without informed consent for deceased patients and/or those who cannot be contacted at the time of enrollment, after making every reasonable effort to contact them (verification of living status, consultation of data reported in clinical documentation, use of any provided phone contacts, as well as obtaining contact data from the registry of insured persons or the resident population).”

Regarding the reasons why informing some interested parties may be impossible, the Company noted “that the population involved in the study is characterized by a mutation (exon 20 insertion) defined as ‘rare’ in the landscape of EGFR mutations, affecting 1-2% of the population suffering from non-small cell lung cancer (NSCLC). Therefore, it is possible that some patients may not be traceable or may not be able to be informed of the treatment due to the rarity of their condition.”

****Cellule.**** Recent scientific evidence has defined this mutation as resistant to the main anti-EGFR drugs, finding that the only therapy currently in use in practice is chemotherapy. Based on data from the EXCLAIM study and retrospective analysis, the median overall survival for this population pre-treated with at least one previous line of chemotherapy is in total (derived from the sum of the activity of the first line and subsequent lines) less than 24 months. Therefore, the aggressiveness of the disease often necessitates the management of post-mortem clinical data. The Company is also able, regarding at least those enrolled in the Regional Health Service who have been hospitalized, to verify their living status through a connection to the Regional Health Registry.

With reference to contactable patients, it has been clarified that it is “foreseen that the patient will sign two separate forms, one relating to participation in the research (“Informed Consent Form for Participation in the Study version 1.0 of July 30, 2021”) and one relating to the use of personal data for research purposes (“Declaration of Consent for the Processing of Personal Data pursuant to EU General Data Protection Regulation 2016/679 and Legislative Decree 196/2003 version 1.0 of July 30, 2021”) which follows the relevant information (“Information on the Processing of Personal Data pursuant to EU General Data Protection Regulation 2016/679 and Legislative Decree 196/2003 version 1.0 of July 30, 2021”)” and that “therefore a model of information for observational research has been proposed.”

Regarding the informational burdens, it has also been specified that “The method by which, pursuant to Article 6 paragraph 3 of the Deontological Rules for treatments for statistical or scientific research purposes of December 19, 2018, it is intended to inform the non-contactable interested parties (i.e., deceased, for the benefit of any third parties entitled under Article 2-terdecies of the Code) regarding the treatments carried out, is represented by the publication of the information on the Company’s institutional website.”

With particular reference to the methods of data collection and processing, it is further specified in the VIP that “data are extrapolated from the company’s medical records system DnWeb and/or ArchiAmb, which can be consulted through access with personal credentials or SPID. Access with credentials is restricted to medical staff employed in the Company (AOU Careggi) who are part of the experimental group. Registration: Data are transferred and recorded on the RedCap portal [...] with access restricted by user and temporary password held only by the doctors who are enabled to access the individual database [...]. The database is organized into 9 sections [...]. Each section has some fields where the data can be entered with constraints related to the type of data entered [...]. The platform generates a unique identification code associated with each subject involved in the Study, which allows researchers to maintain a local association with the respective personal data. The ability to trace the origin of the data is justified by the need to conduct follow-up studies for patients being treated at the involved Operational Units. [...]. The acquired data are stored within the aforementioned database for the entire duration of the study. [...] Each individual center, through activated personal credentials, one for the Principal Investigator and one for a sub-investigator, can access its own data to view and/or modify them.”

The VIP correctly indicates that the data are processed in a pseudonymized form. It also includes a section titled “applicable standards for processing” where the indication “e.g., Codes of Conduct, Guidelines, International Standards” is found.

The VIP also contains a section dedicated to risk management in which the Company limits itself to indicating the main threats that could materialize the risks associated with the processing of personal data such as "unauthorized access to data," "undesired modifications of data," and "data loss." In this regard, the data controller further clarified that "Regarding the risk of unauthorized access to data, the probability of the risk is considered negligible as the data are managed on the database in pseudonymized mode, and the server hosting the database is accessible exclusively through the https (TLS) protocol, excluding any access of another type (SMB, FTP, or others). Systematic service accesses (for maintenance or software updates) are allowed only through encrypted protocols (ssh or similar) and only from the company intranet. Administrative credentials are held only by authorized personnel. The application management credentials are personal and issued only to authorized employees who have been instructed regarding their proper custody and use. Regarding the risk of data modifications, their probability is considered negligible in light of the planned measures. Data are subjected to daily backups, with the possibility of rapid restoration in case an undesired modification occurs. Write access to the data is reserved for selected users and occurs through interfaces that minimize the probability of error. Regarding the risk of data loss, it is evaluated as indefinite but substantially low. The estimate considers the redundant hardware structures on which the system is based, the systematic backup procedures, and the intrinsic resilience of the data center hosting the application. For any data loss caused by unfaithful operators, the considerations of the previous points apply (the people).

****Authorized Processing of Data****

The authorized processing is extremely limited and justified.

Regarding the retention periods of the data, it has been clarified that "the duration of the study is 12 months, with an additional follow-up of 30 months. To this period, an extension for data retention of 7 years must be added, according to current regulations (observational studies not being included in Regulation EU 536/2014, which extends retention for drug and device trials to 'at least 25 years')." In particular, this retention period of at least 7 years has been "derived from Article 18 of Legislative Decree No. 200 of November 6, 2007, implementing Directive 2005/28/EC, which contains principles and detailed guidelines for good clinical practice concerning medicinal products under investigation for human use, as well as requirements for the authorization of the manufacture or importation of such medicinal products," also in light of the fact that "this regulation was cited in the Provision of this Authority No. 52 of July 24, 2008, containing Guidelines for the processing of personal data in the context of clinical trials of medicinal products, in which, in § 13, observational studies were referenced."

The aforementioned term has indeed "seemed appropriate both to this Company and to the territorially competent Ethics Committee (Wide Area Ethics Committee - CEAVC), particularly in reference to observational studies, for which data retention is substantially functional to a possible subsequent verification of the correct use of the information collected and processed."

The Company has specified that it retains "a list of study participants and their codes in a double-coded identification file (for each enrolled subject, initials of first and last name are indicated in the same field and date of birth in the format DD-MM-YYYY), and at the end of the Study, it will destroy this file by eliminating the correlation between data and patients, and aggregating the data according to a threshold value of 4; if this value is not achievable, the data will be deleted."

From another perspective, considering that the Study is aimed (also) at evaluating the effectiveness of a drug, as well as, if necessary, collecting and transmitting to the sponsor information regarding any adverse events, the Company has clarified that "[...] the processing concerns an observational study related to a drug dispensed for compassionate use, authorized by an AIFA program and, for each patient, by a specific opinion of the CEAVC. This drug was indeed under investigation, but EMA, with communication of August 19, 2022, informed us that the pharmaceutical company had withdrawn the request for marketing authorization on July 20, 2022. Compassionate use is independent of the trial, and the legal basis for the communication does not appear to be represented by Regulation 536/2014

(art. 41), but by Decree of September 7, 2017, which in Article 1, paragraph 1, letter f provides for the indication of nominal therapeutic use (IPRP - individual patient request program) and, in particular, regarding the communication of adverse events, Article 7, paragraph 2, prescribes the following: Physicians and other healthcare professionals, in the context of their activities, are required to report to the pharmacovigilance manager of their healthcare facility or directly to the national pharmacovigilance network through the AIFA web portal and to the competent ethics committee, any suspected adverse reactions, specifying that it concerns a medicinal product used under this decree; the report must be sent within two days and, for biological medicinal products, no later than thirty-six hours, in a complete manner and according to the methods published on the official AIFA website. Subsequently, it will be the responsibility of the pharmacovigilance manager of the healthcare facility of the reporter to notify the report to AIFA and the Company that provided the medicinal product used under this decree according to the methods and timelines provided by the decree of the Minister of Health of April 30, 2015. The purpose is therefore that provided for by Article 2 sexies, paragraph 2, letter z) of the Code, for the item relating to Pharmacovigilance."

****2. Applicable Regulations****

Preliminarily, it is represented that the processing of personal data must occur in compliance with the applicable regulations regarding the protection of personal data.

According to the Regulation, personal data must be processed "lawfully, fairly, and transparently concerning the data subject" (principle of "lawfulness, fairness, and transparency" (art. 5, par. 1, lett. a) of the Regulation).

The principle of lawfulness requires that every processing is based on a specific legal basis (art. 6 of the Regulation). In relation to special categories of data, including health data, Article 9 of the Regulation establishes a general prohibition on processing unless one of the specific exemptions to this prohibition applies, among which is the consent of the data subject.

In cases where the condition of lawfulness is represented by consent, it must be given through a positive act by which the data subject expresses a free, specific, informed, and unequivocal will regarding the processing of personal data concerning them (Recitals 32, 42, and 43, arts. 5, 6, par. 1, lett. a) and 7 of the Regulation and Guidelines 5/2020 on consent under Regulation (EU) 2016/679, adopted by the European Data Protection Board on May 4, 2020).

With specific reference to special categories of data, such consent, considering the nature of such data, particularly sensitive from the perspective...

of rights and fundamental freedoms, must be not only explicit but also manifested in writing (Article 9, paragraph 2 letter a) of the Regulation and paragraph 4 of the aforementioned Guidelines 5/2020 on consent and Article 7, paragraph 2, letter b) of the Ethical Rules for processing for statistical or scientific research purposes published pursuant to Article 20, paragraph 4, of Legislative Decree No. 101 of August 10, 2018, of December 19, 2018, Annex A5 to the Code (web doc no. 9069637).

In this context, the European Data Protection Committee has clarified that "the informed consent required by the clinical trial regulation should not be confused with consent as a legal basis for the processing of personal data under the General Data Protection Regulation. The provisions of Chapter V of the clinical trial regulation relating to informed consent, particularly Article 28, primarily respond to the fundamental ethical requirements of research projects involving human beings arising from the Declaration of Helsinki. The obligation to obtain informed consent from participants in a clinical trial is primarily a measure that ensures the protection of the right to human dignity and the right to personal integrity as provided for in Articles 1 and 3 of the Charter of Fundamental Rights of the European Union; it is not designed to comply with data protection obligations. Under the General Data Protection Regulation, consent to processing must be given freely and must be specific, informed, and unambiguous, and, in relation to special categories of data such as health data, it must be explicit" (see points 15, 16, and 17 of Opinion 3/2019 regarding questions and answers on the interaction between the clinical trial regulation and the General Data Protection Regulation (Article 70, paragraph 1, letter b), adopted on January 23, 2019).

It is also highlighted the principle of data retention limitation according to which data must be processed and retained only for as long as necessary for the purposes of collection (Article 5, paragraph 1 letter e) of the Regulation).

In this framework, the processing of personal data for scientific research purposes must also be carried out in compliance with the Code, the Prescriptions, and the Ethical Rules, which constitute an essential condition for the lawfulness and correctness of the processing (Article 2-quater of the Code and Article 21, paragraph 5, of Legislative Decree No. 101 of August 10, 2018). Specifically, Article 110 of the Code, which concerns medical, biomedical, and epidemiological research, states that “The consent of the data subject for the processing of health-related data for scientific research purposes in the medical, biomedical, or epidemiological field is not necessary when [...] due to particular reasons, informing the data subjects proves impossible or involves a disproportionate effort, or risks making it impossible or severely jeopardizing the achievement of the research objectives. In such cases, the data controller adopts appropriate measures to protect the rights, freedoms, and legitimate interests of the data subject, the research program is subject to a reasoned favorable opinion from the competent ethical committee at the territorial level, and must be submitted for prior consultation with the Authority pursuant to Article 36 of the Regulation.”

In this regard, “when it is not possible to obtain the consent of the data subjects, the data controllers must document, in the research project, the existence of the reasons considered entirely particular or exceptional, for which informing the data subjects proves impossible or involves a disproportionate effort, or risks making it impossible or severely jeopardizing the achievement of the research objectives” (see point 5.3 of the Prescriptions regarding the processing of personal data carried out for scientific research purposes).

Personal data must also be processed in compliance with the principle of transparency (Article 5, paragraph 1 letter a) of the Regulation), providing the data subjects in advance with the information referred to in Article 13 of the Regulation, in the case of data collected directly from them, or pursuant to Article 14, in the case of data collected from third parties.

It is also noted that the aforementioned regulations provide that, if the data is obtained from third parties, as in the present case, the data controller may not provide the information referred to in paragraphs 1 to 4 of Article 14 of the Regulation, to the extent that communicating such information proves impossible or involves a disproportionate effort. This, in particular, within the scope of processing carried out for scientific research purposes, without prejudice to the conditions and guarantees provided for in Article 89, paragraph 1 of the Regulation. In such cases, the data controller is still required to adopt appropriate measures to protect the rights, freedoms, and legitimate interests of the data subject, including making the information public (Article 14, paragraph 5, letter b) of the Regulation).

On this point, the Ethical Rules for processing for statistical or scientific research purposes, Annex A5 to the Code, provide that, if the data controller collects personal data from third parties and providing information to the data subject involves a disproportionate effort compared to the protected right, it must adopt suitable forms of publicity, indicating by way of example certain specific methods (Article 6, paragraph 3).

The regulation on the protection of personal data also concerns data subject to prior pseudonymization, which is understood as: “the processing of personal data in such a way that the data...

personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and subject to technical and organizational measures intended to ensure that such personal data cannot be attributed to an identified or identifiable natural person” (recital 26 and art. 4, point 5 of the Regulation).

Pseudonymization is a measure of extreme importance in the field of scientific research, particularly in order to ensure effective application of the principle of minimization (art. 5, par. 1, lett. c) and 89 of the Regulation).

The regulation on the protection of personal data does not apply to anonymous data. In this regard, it is also useful to clarify that “(...) information that does not relate to an identified or identifiable natural person or to personal data rendered sufficiently anonymous to prevent or no longer allow the identification of the data subject” is considered anonymous, including for processing carried out for statistical or research purposes (see recital 26 of the Regulation). However, the risk of re-identification of the data subject must be carefully assessed, taking into account “all means, [...], that the data controller or a third party can reasonably use to identify that natural person directly or indirectly. To ascertain the reasonable likelihood of using means to identify the natural person, all objective factors should be considered, including the costs and time required for identification, taking into account both the technologies available at the time of processing and technological developments” (see recital 26 of the Regulation and WP29 Opinion 05/2014 on Anonymisation techniques, adopted on April 10, 2014).

In particular, anonymization cannot be considered achieved merely by removing the identifying details of the data subject or replacing them with a pseudonymous code. An anonymized data set is indeed only such if it does not allow, in any way, the direct or indirect identification of a person, taking into account all means (economic, information, technological resources, skills, time) available to those (data controller or another party) attempting to use such tools to identify a data subject. An anonymization process cannot be deemed effective if it does not prevent anyone using such data, in combination with “reasonably available” means, from being able to:

1. isolate a person in a group (single-out);
2. link an anonymized data set to data referring to a person present in a distinct data set (linkability);
3. deduce new information relating to a person from an anonymized data set (inference).

Lastly, regarding the impact assessment, the Regulation identifies the minimum content of such a document, which particularly includes the assessment of risks to the rights and freedoms of data subjects and the measures to address the identified risks, which must include guarantees, security measures, and mechanisms to ensure the protection of personal data and demonstrate compliance with the Regulation (art. 35, par. 7, lett. c) and d); Guidelines on data protection impact assessment and the criteria for determining whether a processing “may present a high risk” under Regulation 2016/679 - WP248rev.01, adopted on April 4, 2017, as amended and last adopted on October 4, 2017).

3. Evaluations of the Authority

3.1. Legal bases for data processing

From the documentation examined and following the preliminary investigation carried out, the Authority believes that the Company has correctly identified the legal bases for processing, adequately specifying, as better described in paragraph 1, the reasons justifying the impossibility of informing the data subjects and obtaining valid consent. This circumstance is particularly related to the probable death of the majority of the patients intended to be enrolled due to the high incidence of mortality of the observed condition, as well as the reasonable and proportionate effort intended to be made to attempt to contact each of them, including through the regional health registry and the registry of the resident population (point 5.3 of the Prescriptions). On another note, in accordance with the provision of art. 110, paragraph 1, second sentence of the Code, under which the research program must be subject to a prior reasoned favorable opinion from the competent ethical committees at the territorial level, it remains that the participating Centers may begin the processing of personal data necessary for the realization of the Study only after obtaining the favorable opinions of their respective ethical committees, as the presence of this element constitutes a condition for the lawfulness of the processing of personal data for the purposes in question, where it is not possible to obtain the consent of the data subjects (see provision no. 202 of October 29, 2020, web doc 9517401 and provision no. 406 of November 1, 2021, web doc 9731827).

3.2. Measures pursuant to art. 89 of the Regulation

The Authority, having taken note of the clarifications recently provided by the Company, which stated that it had improperly used the term “anonymization of data” in the context of the processing carried

out for the realization of the Study, as it actually concerns pseudonymized data, notes that the aforementioned Company has correctly applied art. 89.

of the Regulation, providing that the data shall be subject to minimization implemented through specific pseudonymization measures throughout the processing phase, as indicated in the documentation on file in the proceedings and briefly described in the previous paragraph 1.

Regarding the anonymization of data, which is to take place at the end of the retention period indicated as 7 years, also in order to allow the dissemination of the results of the Study, the Company has declared that, once the correlation list between the direct identifiers of the patients and the pseudonymous codes assigned to each of them has been eliminated, the data will be aggregated “[...] according to a threshold value of 4; if this value cannot be reached, the data will be deleted.”

With reference to the aforementioned aggregation techniques, it is necessary to consider that the availability of a high number of aggregated statistics concerning a sample composed of a very limited number of patients may increase the identifying power of each of them, up to the possible complete reconstruction of a dataset (so-called “reconstruction attack”). To avoid this, the number of statistics to be disseminated must be significantly lower than the number of variables intended for disclosure. In other words, by ensuring the dissemination of a limited number of statistics, it is avoided that through mathematical calculations, one could arrive at the identification of individual subjects belonging to the sample.

In light of the above, it is deemed necessary that the Company, at the end of the data retention period for the conduct of the Study, indicated as 7 years, considering the number of variables subject to aggregation, ensures that the number of aggregated statistics to be made known is significantly lower than the number of considered variables; this, in order to avert the risk of reconstruction of data relating to individual individuals.

Furthermore, within the framework of the periodic checks that the data controller is required to carry out also regarding the persistence of the effectiveness of the data anonymization measures and technological evolution, it is deemed necessary that the Company commits to removing any singularity, should it become aware of it by any means in a phase subsequent to the application of the aforementioned anonymization techniques, and to keep track of such events in order to repeat the risk assessment of re-identification upon reaching 1% of singularities identified out of the total records included in the dataset (see, on this point, the Opinion issued on June 30, 2022, available at www.gdpd.it doc. web 9791886).

3.3. The roles of personal data protection of the subjects involved in the Study

In the documentation transmitted by the Company, in representing the multicentric nature of the Study, it is stated that the entities participating as Participating Centers operate as autonomous data controllers and that the Principal Investigator is qualified as a person expressly designated pursuant to 2-quaterdecies of the Code who is “specifically responsible for the data processing necessary for this activity, also with reference to the authorized persons involved in it.”

In this regard, it is believed that the organizational structure implemented for the realization of the Study is compliant with the regulatory framework on personal data protection and as such suitable to exclude that unauthorized third parties may be involved in the processing operations of health data from the patients enrolled in the aforementioned Study and compliant with the principle of fairness and transparency (art. 5, par. 1 lett. a) of the Regulation and Guidelines 07/2020 on the concepts of data controller and data processor pursuant to the GDPR, Version 2.0 Adopted on July 7, 2021).

3.4. Measures to ensure the effectiveness of the principle of transparency towards the patients enrolled in the Study

Regarding the information obligations, it is first noted that the model of information acquired in the proceedings (see document titled “Annex 4_Information and consent”) is only that relating to the information to be provided to the living data subjects pursuant to art. 13 of the Regulation, with respect to which it is noted that:

in the document acquired in the proceedings, the legal bases for processing, including those carried out ex lege such as those related to pharmacovigilance activities, are not clearly represented to the data subjects nor is the legal basis on which any transfer of data to third countries is carried out specified (see arts. 13, par. 1 lett. c), 14, par. 1 lett. c), 45 et seq. of the Regulation and point 12 et seq. of the Guidelines on transparency pursuant to Regulation 2016/679 adopted by the Article 29 Working Party on November 29, 2017, amended version adopted on April 11, 2018).

in the event of revocation of consent by the data subject, although all processing based on consent remains legitimate, it is not specified that the controller must cease processing activities, in the absence of another legal basis justifying retention for further processing and that therefore the data must be deleted (see points 22 et seq. of Opinion 3/2019 regarding questions and answers on the interaction between the clinical trial regulation and the general data protection regulation (article 70, paragraph 1, letter b)), cited);

the indication in point 4, titled “data retention” of the right of the data subject “to request, at any time, the deletion of data, in compliance with the GDPR and data protection law” is not relevant given the right to erasure indicated in the subsequent point 5, titled “exercise of rights.” It is therefore necessary for the Company to modify the transmitted document accordingly.

With specific regard to the methods for providing information to non-contactable data subjects, the Company has stated that the information for non-contactable patients, prepared pursuant to Article 14, paragraph 5, letter b) of the Regulation, will be published on its website.

That said, considering that the Study involves numerous participating Centers in addition to the Sponsor, also to ensure the effective application of the aforementioned principles of fairness and transparency, it is deemed necessary for the Company to make public, for the entire duration of the Study, the information to be provided to the data subjects, pursuant to Article 14 of the Regulation, also through a specific insertion on the institutional websites of the centers involved in the Study in an easily accessible section.

3.5. Security measures implemented

The Company, as the data controller, as mentioned above and as required by the procedure pursuant to Articles 110 of the Code and 36 of the Regulation, has submitted to the Authority the VIP related to the treatments necessary for the realization of the Study, in which the technical and organizational measures are specifically identified, briefly described in paragraph 1, provided for the security of the processed data.

It should be noted that the implementation of the measures referred to in Article 89 of the Regulation, aimed, in particular, at the effective application of the principle of minimization, does not exempt the data controller from also introducing appropriate technical and organizational measures pursuant to Article 32 of the Regulation, for the effective application of the principle of integrity and confidentiality of data (Article 5, paragraph 1, letter f) of the Regulation).

From this document, in addition to what has been highlighted in the previous paragraph 1, it emerges that the Company, in order to ensure compliance with the principle of integrity and confidentiality, has established appropriate and suitable measures to protect the rights and freedoms of the cohort of data subjects involved in the Study.

ALL OF THE ABOVE, THE AUTHORITY

pursuant to Article 110 of the Code and Article 36 of the Regulation, expresses a favorable opinion to the Azienda Ospedaliera Universitaria Careggi, with legal headquarters at Largo G.A. Brambilla, 3 - 50134 Florence, Tax Code and VAT number: 04612750481, regarding the processing of personal data for the purposes of medical, biomedical, and epidemiological research, relating to the cohort of deceased or non-contactable patients enrolled in the multicenter study, “Italian multicenter observational retrospective and prospective study to evaluate the safety and efficacy of mobocertinib in patients pre-treated with metastatic non-small cell lung cancer with EGFR exon 20 insertion. (MOBO-real)” on the condition that the Company:

- a) at the end of the data retention period for the conduct of the Study, considering the number of variables subject to aggregation, ensures that the number of aggregated statistics to be made known is significantly lower than the number of considered variables (point 3.2);
- b) in the context of the periodic checks that the data controller is required to carry out also with reference to the persistence of the effectiveness of the data anonymization measures and technological evolution, commits to remove any singularity, should it become known by any means at a later stage after the application of the aforementioned anonymization techniques, and to keep track of such events in order to repeat the risk assessment of re-identification upon reaching 1% of singularities identified out of the total records included in the dataset (point 3.2);
- c) modifies the information provided to data subjects, pursuant to Article 13 of the Regulation (point 3.4): clearly indicating the legal bases for the processing including the legal basis under which any transfer of data to third countries is carried out; specifying, in case of revocation of consent by the data subject, that the controller must cease processing activities in the absence of another legal basis justifying retention for further processing and that therefore the data will be deleted; removing in point 4 titled “data retention” of the document named “Annex 4_Information and consent,” the right of the data subject “to request, at any time, the deletion of data, in compliance with the GDPR and data protection law” as the right to erasure is already mentioned in the subsequent point 5, titled “exercise of rights.”
- d) makes public the information to be provided to data subjects, pursuant to Article 14 of the Regulation, also through a specific insertion on the institutional websites of the centers involved in the Study in an easily accessible section (point 3.4).

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, July 18, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei